BÁO CÁO TÌM HIỂU ĐỒ ÁN TỐT NGHIỆP

Đánh giá khả năng áp dụng CVE đối với hệ thống web bằng cách kết hợp nhiều nguồn bằng chứng

Evidence-based CVE Applicability for Web-facing Targets

---

1 Đặt vấn đề và mục tiêu nghiên cứu

1.1 Lý do chọn đề tài

Khi biết một website đang sử dụng phần mềm nào và ở phiên bản nào, công cụ quét có thể đối chiếu với dữ liệu CVE để tìm các lỗ hổng liên quan. Nhưng danh sách CVE khớp phiên bản vẫn chưa trả lời được câu hỏi: *lỗ hổng nào thực sự áp dụng cho hệ thống đang chạy?* Một lỗi có thể chỉ gây tác động khi tính năng liên quan được bật, khi người dùng có một quyền nhất định hoặc khi hệ thống sử dụng cấu hình cụ thể. Trạng thái bản vá cũng cần được xét đến, nhất là khi bản vá được đưa vào một bản phần mềm mà chuỗi phiên bản không thay đổi theo cách dễ nhận biết.

Đồ án tập trung vào bước đánh giá này. Từ thông tin về sản phẩm, phiên bản và các dấu hiệu thu được qua HTTP, phương pháp sẽ đối chiếu với thông báo bảo mật, lịch sử phát hành và tài liệu bản vá để xác định CVE có áp dụng cho triển khai đó hay không. Cách tiếp cận này đòi hỏi phân biệt rõ ba mức: phiên bản phần mềm bị ảnh hưởng,hệ thống triển khai thỏa mãn điều kiện của lỗi, và lỗi đã được khai thác thành công. Mục tiêu của đồ án đang hướng đến hiện tại chính là mức thứ hai, đồng thời việc tái tạo lỗi trong môi trường cách ly phục vụ kiểm chứng nhãn chuẩn.

Lý do ta lựa chọn kết hợp nhiều nguồn là vì mỗi nguồn chỉ phản ánh một phần của vấn đề. Dữ liệu phiên bản giúp xác định các CVE cần xem xét, tài liệu của nhà cung cấp mô tả điều kiện của lỗi, còn phản hồi HTTP cung cấp dấu hiệu về hệ thống thực tế. Đồ án sẽ kiểm tra xem việc ghép các bằng chứng này có giúp kết luận chính xác hơn hay không. Khi thiếu thông tin, phương pháp có thể trả lời `Unknown` thay vì buộc phải chọn một kết luận dương hoặc âm.

1.2 Câu hỏi và mục tiêu nghiên cứu

Câu hỏi chính của đồ án là: *Kết hợp nhiều nguồn bằng chứng có giúp đánh giá khả năng áp dụng CVE cho một triển khai web chính xác hơn so với dùng một nguồn riêng lẻ không? Những trường hợp nào được cải thiện và những trường hợp nào vẫn chưa thể kết luận?*

Đồ án hướng đến ba mục tiêu:

1. Xây dựng phương pháp thu thập và kết hợp bằng chứng, đưa ra kết luận `Applicable`, `Not Applicable` hoặc `Unknown`, kèm lý do và nguồn thông tin hỗ trợ.
2. Xây dựng bộ dữ liệu đánh giá với ít nhất 30 CVE khác nhau. Nhãn chuẩn được kiểm chứng trong môi trường thử nghiệm và lưu cùng hồ sơ phiên bản, cấu hình, kết quả tái tạo.
3. So sánh phương pháp kết hợp với phương pháp dùng một nguồn, đo các chỉ số đánh giá và phân tích nguyên nhân của những kết luận đúng, sai hoặc chưa xác định.

1.3 Đối tượng và phạm vi

Phạm vi thực nghiệm tập trung vào WordPress và một số plugin, Drupal và Roundcube. Đây là các hệ thống có giao diện web, phù hợp với việc thu bằng chứng qua HTTP và dựng môi trường tái tạo lỗi. Ngoài ra chúng ta sẽ quan sát thêm Apache/nginx để dùng cho một số trường hợp bổ trợ. Danh sách plugin và CVE cụ thể sẽ được chốt sau bước xác minh và thí điểm. Tạm thời các framework khác chưa nằm trong kế hoạch ban đầu.

Phương pháp sử dụng dữ liệu công khai về CVE và những gì quan sát được từ mục tiêu qua HTTP. Cấu hình nội bộ, phiên bản cài đặt, trạng thái cơ sở dữ liệu và thông tin container được giữ riêng để xác lập nhãn chuẩn. Nếu sử dụng tài khoản để quan sát, kết quả sẽ được tách khỏi trường hợp không đăng nhập.

2 Tổng quan nghiên cứu liên quan

Vulnerability-Affected Versions Identification: How Far Are We? (VAVI) đánh giá 12 công cụ xác định phiên bản bị ảnh hưởng trên 1.128 CVE của các dự án C/C++ [1]. Bài báo cho thấy cần kiểm tra kỹ mối liên hệ giữa bản vá, lịch sử phát hành và các phiên bản còn chứa lỗi. Đồ án tham khảo cách xây dựng nhãn chuẩn độc lập, tổ chức đánh giá và phân tích nguyên nhân dự đoán sai của công trình này. Phạm vi của VAVI là mã nguồn và lịch sử phát hành, nên kết quả của bài chưa trả lời trực tiếp câu hỏi về cấu hình của một hệ thống web đang chạy.

Vuln2Action kết hợp các nguồn tri thức an ninh để sinh hướng dẫn tái tạo lỗ hổng và liên kết với tài liệu exploit [2]. Nghiên cứu này gợi ý cách nối dữ liệu CVE, CWE, CPE, CAPEC và Exploit-DB. Tuy nhiên, đầu ra được đánh giá chủ yếu dưới dạng văn bản, chưa được kiểm chứng bằng thực thi trong môi trường cách ly. Vì vậy, độ tương đồng của hướng dẫn sinh ra chưa đủ để xác nhận lỗ hổng trên một triển khai cụ thể.

Từ hai bài báo, đồ án rút ra hai yêu cầu: bằng chứng cần được tổ chức theo điều kiện của từng CVE, và nhãn dùng để chấm phương pháp cần có kiểm chứng riêng. Phần khảo sát tiếp theo sẽ bổ sung các nghiên cứu về nhận diện phần mềm web và kiểm tra tiền điều kiện không khai thác. Qua đó, đồ án sẽ làm rõ điểm khác biệt của phương pháp kết hợp bằng chứng đang đề xuất.

3 Phương pháp nghiên cứu đề xuất

3.1 Thu thập và kết hợp bằng chứng

Với mỗi mục tiêu web và CVE cần đánh giá, quy trình thu thập hai nhóm thông tin:

- **Thông tin về CVE:** dữ liệu CVE/NVD, định danh CPE, thông báo bảo mật, lịch sử phiên bản và tài liệu bản vá [3, 4, 5]. Nhóm này mô tả sản phẩm, phiên bản và điều kiện liên quan đến lỗi.
- **Thông tin từ mục tiêu:** dấu hiệu nhận diện sản phẩm, phiên bản, tính năng hoặc điều kiện triển khai xuất hiện trong phản hồi HTTP. Nhóm này dùng để đối chiếu điều kiện của CVE với hệ thống đang xét.

Hướng xây dựng ban đầu là dùng các luật kết hợp bằng chứng. Các luật cần chỉ ra khi nào thông tin đủ để kết luận, cách xử lý khi các nguồn mâu thuẫn và khi nào phải giữ trạng thái chưa xác định. Đầu ra gồm:

- `Applicable`: bằng chứng cho thấy triển khai thỏa mãn các điều kiện liên quan của CVE.
- `Not Applicable`: bản phần mềm đã được xác minh không bị ảnh hưởng, hoặc các đường gây tác động của lỗi bị loại trừ bởi các điều kiện cấu hình của hệ thống.
- `Unknown`: thông tin thu được chưa đủ để kết luận.

Mỗi kết luận sẽ đi kèm nguồn và lập luận hỗ trợ để có thể kiểm tra lại. Cách viết luật cụ thể sẽ được hoàn thiện từ kết quả thí điểm.

3.2 Xây dựng bộ dữ liệu và nhãn chuẩn

Mỗi một trường hợp đánh giá sẽ được xác định bởi *sản phẩm, phiên bản/bản build, cấu hình và CVE*. Cùng một CVE có thể được kiểm tra trên nhiều phiên bản hoặc cấu hình. Vì vậy, mục tiêu ít nhất 30 CVE được tính theo số mã CVE khác nhau; số trường hợp đánh giá có thể lớn hơn.

Mỗi ứng viên cần có tài liệu đáng tin cậy, xác minh được bản phần mềm và có cách tái tạo rõ ràng. Việc chọn mẫu sẽ xét sự đa dạng về sản phẩm và loại lỗi, đồng thời ghi lại lý do chọn hoặc loại từng CVE. Các phiên bản được kiểm tra khả năng tải và triển khai trước khi đưa vào bộ dữ liệu.

Nhãn chuẩn được xác lập từ hồ sơ bản phần mềm, thông báo bảo mật, cấu hình thực tế và kết quả tái tạo. Một trường hợp có nhãn dương khi tác động của lỗi được kiểm chứng. Nhãn âm có hai căn cứ: bản phần mềm không bị ảnh hưởng hoặc đã vá; hoặc mỗi đường gây tác động liên quan đều thiếu ít nhất một điều kiện bắt buộc, được kiểm tra bằng đối chứng. Nếu PoC thất bại mà chưa xác định được nguyên nhân, trường hợp đó được giữ là `Unresolved` và báo cáo riêng.

`Unresolved` là trạng thái chưa xác định được nhãn chuẩn; `Unknown` là câu trả lời của phương pháp khi thiếu bằng chứng. Hai trạng thái này được theo dõi riêng. Người gán nhãn không xem dự đoán của phương pháp. Phương pháp cũng không được nhận cấu hình nội bộ hoặc kết quả PoC dùng để tạo nhãn.

3.3 Thí nghiệm thí điểm

Trước khi xây dựng đầy đủ bộ dữ liệu, đồ án sẽ khảo sát ba CVE có những yêu cầu khác nhau:

- **Really Simple Security, CVE-2024-10924:** thử xem điều kiện bật xác thực hai yếu tố có thể nhận biết từ bên ngoài qua HTTP hay không.
- **Drupal, CVE-2019-6340:** kiểm tra các cấu hình dịch vụ web để xử lý trường hợp một CVE có nhiều đường gây tác động.
- **Roundcube, CVE-2020-12625:** tái tạo XSS bằng trình duyệt và khảo sát thông tin có thể thu khi không đăng nhập hoặc dùng tài khoản thường.

Phần thí nghiệm này sẽ trả lời hai câu hỏi: có dựng và tái tạo được lỗi không, và có quan sát được các điều kiện liên quan mà không kích hoạt lỗi không? Kế hoạch hiện tại giới hạn ở 20 yêu cầu HTTP cho mỗi trường hợp. Danh sách đường dẫn và quyền truy cập được cố định trước khi thu dữ liệu. Bằng chứng cho phương pháp được thu trước khi chạy PoC hoặc trên môi trường đã khôi phục về trạng thái tương đương. Đối với XSS, kết quả thực thi trong trình duyệt chỉ dùng để kiểm chứng nhãn.

Nếu một ca không tái tạo được hoặc không cung cấp đủ dấu hiệu HTTP, nguyên nhân sẽ được ghi lại. Những kết quả này giúp xác định phạm vi có thể thực hiện và giới hạn của phương pháp trước khi mở rộng lên 30 CVE.

3.4 So sánh và đánh giá

Thí nghiệm so sánh phương pháp dùng một nguồn bằng chứng (baseline) với phương pháp kết hợp nhiều nguồn (fusion). Nguồn dùng cho baseline sẽ được chọn sau thí điểm. Cả hai được chạy trên cùng các trường hợp, cùng nhãn chuẩn và cùng phạm vi quan sát. Các nguồn thông tin được sử dụng và chi phí thu thập sẽ được ghi rõ.

Đánh giá sẽ sử dụng precision, recall, F1, tỷ lệ kết luận (coverage), tỷ lệ `Unknown` và số kết luận dương/âm sai. Precision phản ánh độ đúng của các kết luận dương; recall phản ánh số trường hợp có lỗi được phương pháp nhận ra. Coverage cho biết phương pháp đưa ra được kết luận trên bao nhiêu trường hợp. Các chỉ số này cần được xem cùng nhau: trả lời ít trường hợp nhưng đúng không đồng nghĩa với phát hiện tốt toàn bộ tập đánh giá.

Khi tính recall, mọi trường hợp có nhãn chuẩn `Applicable` đều nằm trong mẫu số, kể cả trường hợp phương pháp trả `Unknown`. Nếu tính độ chính xác chỉ trên các trường hợp có kết luận, kết quả sẽ được báo cáo cùng coverage. Dữ liệu dùng để chỉnh luật được tách khỏi dữ liệu đánh giá; các trường hợp cùng CVE được giữ theo nhóm để hạn chế rò rỉ thông tin.

Phần phân tích sẽ tập trung vào việc nguồn nào giúp cải thiện kết luận, nguồn nào còn thiếu và vì sao vẫn xảy ra sai sót. Kết quả cũng sẽ chỉ ra những trường hợp kết hợp nhiều nguồn không mang lại lợi ích.

3.5 Công nghệ sử dụng

- **Hệ điều hành lab:** Ubuntu Server 22.04 LTS, chạy môi trường tái tạo cách ly.
- **Docker** — dựng các bản phần mềm lỗi và đã vá, với image và phiên bản được cố định.
- **MariaDB** — cơ sở dữ liệu dùng chung cho các ứng dụng PHP như WordPress, Drupal và Roundcube.
- **Python** — xây dựng chương trình thu thập, kết hợp bằng chứng và chấm điểm.
- **Playwright / Chromium** — trình duyệt headless để kiểm chứng các ca XSS.

Về khả năng tái lập: dịch vụ thử nghiệm chỉ được truy cập qua loopback hoặc SSH; dữ liệu, tài khoản và trạng thái trình duyệt được khôi phục giữa các lần chạy; hồ sơ cấu hình, yêu cầu và phản hồi được lưu cùng hướng dẫn tái lập, tách khỏi phần phân tích kết quả.

4 Công việc đã thực hiện

Quá trình tìm hiểu bắt đầu từ hai bài báo nêu trên và một thử nghiệm nhỏ với Apache HTTP Server. CVE-2021-41773 được chọn để xem xét mối liên hệ giữa phiên bản bị ảnh hưởng và cấu hình quyền truy cập. Thông báo của Apache mô tả cả hai yếu tố này [6].

Trong thử nghiệm ngày 04/10/2026, yêu cầu kiểm tra chỉ nhắm đến một tệp đánh dấu vô hại trong container. CGI không được bật. Các phản hồi và log đã được lưu lại [7]:

Phiên bản	Cấu hình	Kết quả quan sát
Apache 2.4.49	Nới quyền truy cập	HTTP 200; phản hồi chứa nội dung tệp đánh dấu.
Apache 2.4.49	Mặc định	HTTP 403; log ghi nhận yêu cầu bị chặn bởi cấu hình quyền truy cập.
Apache 2.4.51	Mặc định	HTTP 404/400; log ghi nhận đường dẫn không hợp lệ ở phép thử tương ứng.

Hai môi trường cùng phiên bản 2.4.49 cho phản hồi khác nhau khi thay đổi quyền truy cập. Quan sát này minh họa lý do cần xét điều kiện triển khai khi đánh giá CVE. Tuy nhiên, dữ liệu thử và cấu hình đối chứng chưa hoàn toàn tương đương giữa các môi trường, nên kết quả hiện được sử dụng như một thử nghiệm thăm dò.

Một thử nghiệm khác với nginx cho thấy việc tắt thông tin phiên bản làm mất dấu hiệu đó trong header HTTP [7]. Điều này đặt ra yêu cầu xử lý thông tin thiếu: khi không nhận biết được phiên bản, phương pháp cần tìm thêm bằng chứng hoặc giữ `Unknown`.

Hiện chưa chạy ba CVE thí điểm mới, chưa xây dựng bộ dữ liệu 30 CVE và chưa có kết quả so sánh baseline với fusion. Bước tiếp theo là xác minh các bản phần mềm và hoàn thiện môi trường cho thí điểm.

5 Kế hoạch thực hiện

5.1 Tiến độ dự kiến

Đồ án được thực hiện trong giai đoạn tháng 10–12/2026, với kế hoạch 12 tuần như sau. Việc đọc tài liệu và viết báo cáo diễn ra song song với các thí nghiệm.

Thời gian	Công việc chính	Kết quả cần đạt
Tuần 1–2	Hoàn thiện quy trình và thí điểm ba CVE	Hồ sơ thí điểm; phạm vi quan sát; quy trình gán nhãn.
Tuần 2–4	Xác minh CVE, dựng môi trường và xây bộ dữ liệu	Danh mục ít nhất 30 CVE; hồ sơ triển khai và bằng chứng nhãn.
Tuần 4–6	Cài đặt baseline và phương pháp kết hợp	Chương trình thử nghiệm; các luật và cấu hình đánh giá.
Tuần 7–8	Chạy so sánh và phân tích lỗi	Bảng kết quả; phân tích độ chính xác, coverage và giới hạn.
Tuần 8–12	Hoàn thiện luận văn và tài liệu tái lập	Báo cáo đồ án; mã nguồn; bộ dữ liệu và hướng dẫn sử dụng.

5.2 Khó khăn dự kiến và hướng xử lý

Khối lượng tái tạo ít nhất 30 CVE là khó khăn lớn nhất. Mỗi CVE cần đúng bản phần mềm, cấu hình phù hợp và bằng chứng đủ để gán nhãn. Một số phiên bản cũ có thể không tải hoặc chạy được, nên việc xác minh tệp cài đặt cần làm trước khi chốt danh sách. Các thử nghiệm sẽ chạy tuần tự khi tài nguyên máy hạn chế.

Một khó khăn khác là tiền điều kiện không phải lúc nào cũng quan sát được qua HTTP. Những trường hợp này sẽ được ghi nhận qua `Unknown` và coverage, đồng thời phân tích nguyên nhân để làm rõ giới hạn của phương pháp. Báo cáo cũng sẽ xem xét sai số gán nhãn, thiên lệch khi chọn CVE và sự phụ thuộc giữa các nguồn bằng chứng.

5.3 Sản phẩm và kết quả dự kiến

- **Chương trình đánh giá:** một pipeline gồm thu thập bằng chứng và quyết định ba lớp (`Applicable / Not Applicable / Unknown`), triển khai theo hai phiên bản: baseline dùng một nguồn và phương pháp kết hợp nhiều nguồn.
- **Bộ dữ liệu đánh giá:** danh mục ít nhất 30 CVE khác nhau; mỗi CVE gồm các trường hợp (sản phẩm, phiên bản, cấu hình) kèm nhãn chuẩn được kiểm chứng trong môi trường tái tạo, cùng hồ sơ phiên bản, cấu hình và bằng chứng nhãn.
- **Kết quả so sánh định lượng:** bảng đo precision, recall, F1, coverage, tỷ lệ `Unknown` và số kết luận sai, so sánh baseline với phương pháp kết hợp; kèm phân tích trường hợp nào được cải thiện và trường hợp nào chưa kết luận được.
- **Báo cáo và tài liệu tái lập:** báo cáo đồ án trình bày kết quả so sánh, các trường hợp phương pháp hữu ích và các vấn đề còn chưa giải quyết; kèm mã nguồn chương trình, bộ dữ liệu và hướng dẫn tái lập thí nghiệm.

Tài liệu tham khảo

[1] X. Chen, C. Liu, J. Cao, Y. Xiao và cộng sự. “Vulnerability-Affected Versions Identification: How Far Are We?” ASE, 2025. Bản tác giả: `https://arxiv.org/abs/2509.03876`.

[2] S. Kumari và G. Yadav. “Vuln2Action: An LLM-based framework for generating vulnerability reproduction steps and mapping exploits.” *Journal of Information Security and Applications*, tập 99, 2026, bài 104420. `https://doi.org/10.1016/j.jisa.2026.104420`.

[3] CVE Program. *Common Vulnerabilities and Exposures*. `https://www.cve.org/`.

[4] NIST. *National Vulnerability Database*. `https://nvd.nist.gov/`.

[5] NIST. *Common Platform Enumeration*. `https://nvd.nist.gov/products/cpe`.

[6] Apache HTTP Server Project. *Apache HTTP Server 2.4 vulnerabilities*, mục CVE-2021-41773. `https://httpd.apache.org/security/vulnerabilities_24.html`.

[7] Hồ sơ thực nghiệm của đồ án. *Tái tạo có kiểm soát CVE-2021-41773*, ngày 04/10/2026, lưu tại `experiments/reproduce-cve-2021-41773/`; các bản ghi header nginx lưu tại `nginx-visible-headers.txt` và `nginx-hidden-headers.txt` trong thư mục dự án.